ESDS SOFTWARE SOLUTION LTD · INTERNAL — PREPARED FOR CTO REVIEW

SwarajKavach

Next-Gen ESDSWAF · Competitive Capability Assessment

Where we stand against the market leaders, what ships today, and what the roadmap closes

Release v1.0.0 (offline bundle) **Assessment date** 14 August 2026 **Engine** Rust data plane · Go control plane

This document compares **SwarajKavach** — the Next-Gen ESDSWAF platform — against the five vendors that appear on every industry shortlist. It is written to be checkable: every capability claimed for ESDSWAF is marked by whether it **ships and has been tested**, is **partial**, or is **roadmap**. Nothing is listed as delivered on the strength of a design document.

> **Why the marks matter**
>
> An internal audit on 13 August 2026 checked our own customer deck against the source tree and found six capabilities claimed as shipped that the code did not support. All six were corrected. This assessment applies the same standard from the outset — which is why several rows below are deliberately less flattering than earlier material.

1 Market position — the comparison that is actually ours to win

The five recognised leaders are **Cloudflare**, **Akamai** and **Imperva** (Gartner Leaders in the Cloud WAAP Magic Quadrant), with **AWS WAF** as a Challenger and **F5** holding regulated enterprise. The market is **fragmented — no vendor exceeds 15% share**, so there is no dominant incumbent to displace.

Four of those five are global anycast edge platforms. Competing with them on edge footprint would mean building a multi-terabit CDN, and any comparison framed that way is one we lose on capital, not on engineering. **The segment ESDSWAF addresses is the one they structurally cannot serve:**

- **Data that must remain on-premise and in-country** — the binding constraint for Indian BFSI, government and healthcare, and the reason F5 and Fortinet still hold regulated verticals.
- **Delivered by the hosting provider** — the customer's workload is already in an ESDS datacenter. That is a distribution advantage none of the five have with our customers.
- **Single-tenant and customer-dedicated** — dedicated inspection, not a shared multi-tenant edge.
- **Fully air-gapped operation** — installs and runs with no outbound internet dependency.

Our real competitive set is therefore **F5** and **Imperva**, plus in India **Indusface AppTrana**, **HaltDOS** and our own **eNlight Pratihar**.

2 Capability comparison

● Ships today, tested ◐ Partial or opt-in ○ On roadmap, not shipped ◔ Not offered

CAPABILITY	SWARAJ KAVACH	CLOU D-FLARE	AKAM AI	IMPER VA	F5	AWS WAF	SWARAJKAVACH EVIDENCE / NOTE
CORE REQUEST INSPECTION							

CAPABILITY	SWARAJ KAVACH	CLOU D-FLARE	AKAM AI	IMPER VA	F5	AWS WAF	SWARAJKAVACH EVIDENCE / NOTE
Unmodified ModSecurity/CRS rule compatibility	◐	●	●	●	●	●	**Measured 2026-08-20: 334 of 679 shipped SecRule directives load.** 38 are correctly excluded by paranoia-level gating; the remainder are dropped by the Rust importer — unsupported target tokens (656 warnings), `action:score` without a score field (436), `%{}` interpolation (56), and the `validateByteRange` / `validateUrlEncoding` operators. Detection still measures 99.09% app-TP because libinjection and the ML layer cover the same classes, but a ModSecurity-based competitor runs the ruleset unmodified and can say so. **Highest-value engineering item — see the fixes register**
OWASP CRS signature engine	●	●	●	●	●	●	Compiled to a bytecode rule VM, not interpreted per request
Dedicated SQLi / XSS parser	●	●	●	●	●	●	libinjection, plus ML n-gram classifier layered on top
Request-smuggling / protocol abuse	●	●	●	●	●	◐	Enforced at parse time in the Rust data plane
ML anomaly detection	●	●	●	●	◐	◐	Isolation Forest + char-n-gram classifier + FP-suppression model, all embedded
Weighted multi-engine verdict fusion	●	◐	◐	◐	○	○	7 scoring engines fused per paranoia level; adds a 429 soft-deny tier between allow and block
Positive security / entity auto-learning	○	◐	◐	●	●	○	**Gap.** F5's core differentiator. Ours is a configuration toggle only — v1.1
BOT & CLIENT IDENTITY							
JA3 / JA4 TLS fingerprinting	●	●	●	●	◐	○	Real JA4 from a non-destructive ClientHello peek; live values observed
Weighted bot scoring with tiered response	●	●	●	●	◐	◐	0–100 score from JA4 + headers + UA + repeat-offender velocity → allow / JS challenge / CAPTCHA / block
JS proof-of-work challenge	●	●	●	●	○	○	—
Third-party CAPTCHA integration	●	●	◐	◐	○	○	reCAPTCHA / hCaptcha / Turnstile server-side siteverify
Verified good-bot allow-listing (rDNS)	○	●	●	●	◐	○	**Gap.** Reverse-DNS verification deferred — tracked as issue #8
API PROTECTION (WAAP)							
GraphQL firewall	●	●	●	●	◐	◐	Depth + complexity limits, introspection block
Edge JWT / OAuth2 validation	●	●	●	●	●	◐	Signature, exp, iss, aud, scopes; fixed alg allow-list, proof against alg confusion and alg:none
JWKS with key rotation	●	●	●	●	◐	○	Key-by-kid, 300s TTL, refresh on unknown kid, stale-while-error
gRPC firewall	●	◐	◐	◐	◐	○	Per-method allow/deny, reflection block, message and frame size caps
API auto-discovery from traffic	○	●	●	●	●	◐	**Gap.** Toggle only today — v1.1
OpenAPI schema enforcement · BOLA/IDOR	○	●	●	●	●	○	**Gap.** v1.1

CAPABILITY	SWARAJ KAVACH	CLOU D-FLARE	AKAM AI	IMPER VA	F5	AWS WAF	SWARAJKAVACH EVIDENCE / NOTE
AVAILABILITY & VOLUMETRIC DEFENCE							
Global anycast multi-Tbps DDoS scrubbing	○	●	●	●	◐	●	**Structural, not a roadmap item** — see §5. Requires a CDN, not a WAF
Kernel-level L4 drop (eBPF / XDP)	●	○	○	○	○	○	**In service.** This row read *"built, not currently attaching"* earlier on 2026-08-20; the load failure was fixed the same day and re-verified on the same host (Linux 6.8.0-55). Evidence is kernel-side, not our own logs: `ip link show eth0` reports `prog/xdp id … name sentinel_xdp … jited` attached in **native** mode, `bpftool` shows the program JIT-compiled to 477 B with its three maps, and the per-CPU PASS counter advances with live traffic. A seeded blocklist entry appears in the in-kernel LPM trie, confirming the userspace→kernel write path. Degrades gracefully to software mode where XDP is unavailable, and `/healthz` now reports which mode is live
L7 rate limiting	●	●	●	●	●	●	Redis-backed, distributed across nodes
Adaptive L7 DDoS (EWMA / storm detection)	○	●	●	●	◐	◐	**Gap.** Post-v1.1
Admission control under overload	●	●	●	●	●	●	Measured: zero false shedding at 21k req/s sustained
DATA PROTECTION & THREAT INTELLIGENCE							
Outbound DLP on responses	●	◐	○	●	◐	○	block / mask / detect, length-preserving masking
India-specific PII detection	●	○	○	◐	○	○	**Differentiator.** PAN, Aadhaar and Indian mobile patterns built in
Threat-intelligence feed ingestion	●	●	●	●	●	◐	Aggregator + data-plane enforcer; can seed the kernel blocklist directly
Vendor threat-research team & managed rule updates	◐	●	●	●	●	●	**Gap of kind, not code.** We track upstream CRS; we do not staff a research team
DEPLOYMENT MODEL — WHERE THE DIFFERENCE IS STRUCTURAL							
On-premise, single-tenant, customer-dedicated	●	○	○	●	●	○	—
Fully air-gapped install, no outbound dependency	●	○	○	◐	●	○	733 MB offline bundle, SHA256-verified, 10-step installer with dry-run
Traffic and logs never leave the customer datacenter	●	○	○	◐	●	○	**The core commercial argument** for regulated Indian workloads
HA — active/passive pair with VIP failover	●	—	—	●	●	—	Measured failover — see §3. Postgres promotion is deliberately manual: two nodes cannot form a quorum
Clustered control plane (Raft)	●	—	—	●	●	—	3-node Raft; any node accepts writes via leader forwarding
Site onboarding without restart	●	●	●	◐	◐	●	Live in seconds, no impact to other sites. F5 requires policy + virtual-server attach
EXTENSIBILITY & OPERATIONS							

CAPABILITY	SWARAJ KAVACH	CLOU D-FLARE	AKAM AI	IMPER VA	F5	AWS WAF	SWARAJKAVACH EVIDENCE / NOTE
Sandboxed plugins in any language (WASM)	●	◐	○	○	◐	○	**Differentiator.** Hot-swappable. F5 has TCL iRules — powerful but not sandboxed
Per-rule enforcement status observed from the data plane	●	○	○	○	○	○	**No competitor offers this.** The console reports whether each rule is *actually enforced* on every node — an observation, not an inference
Per-path policy overrides	●	●	●	●	●	◐	Longest-prefix-wins, so policy never depends on row order
Learning mode with false-positive-rate reporting	●	●	●	●	●	◐	Built-in `fpr-report.sh` with an explicit go-live gate
AI copilot that drafts rules from your own traffic	●	◐	◐	◐	○	○	—
Customer-facing rule authoring UI	○	●	●	●	●	●	**Gap — deliberately withheld.** The validator does not yet parse our real rule grammar, so exposing it would teach customers invalid syntax
Response action variety	◐	●	●	●	●	●	**Gap.** 5 actions. HaltDOS offers 13 — no tarpit, custom response or redirect yet
HTTP/2 · HTTP/3 (QUIC)	●	●	●	●	◐	●	quinn + h3, reuses the SNI cert resolver, Alt-Svc advertisement
Post-quantum TLS (hybrid X25519 + Kyber)	○	●	◐	○	○	◐	**Gap.** Roadmap — previously mis-stated as shipped in internal material
ASSURANCE & COMPLIANCE							
Independent third-party security audit	○	●	●	●	●	●	**Gap.** Phase 7. Not a feature — a procurement blocker
External red-team engagement	○	●	●	●	●	●	**Gap.** Phase 7
SOC 2 / PCI-DSS / ISO 27001 attestation	○	●	●	●	●	●	**Gap.** ESDS holds certifications; the product needs its own readiness pack
Measured real-traffic false-positive rate	○	●	●	●	●	●	**The most important open gap — see §6**
Auth: local · OIDC/SSO · MFA (TOTP) · API keys · RBAC	●	●	●	●	●	●	5 RBAC roles, multi-tenant with database-enforced row-level security
SAML · LDAP / Active Directory	○	●	●	●	●	●	**Gap.** Not implemented — previously mis-stated as shipped. Post-v1.1

> **On the competitor columns**
> Competitor marks reflect publicly documented capabilities as of August 2026 and are directional for internal planning. They are not contract-grade and should be re-verified against current vendor documentation before any customer-facing use. The SwarajKavach column is the one verified against source code and test output.

3 Measured proof

These are measured figures, not targets. Detection is measured with GoTestWAF v0.5.8 against a fair all-methods origin; performance on a single node with the full pipeline active.

99.60%
COMPOSITE DETECTION SCORE
App true-positive 99.09% · benign-allow 99.29% · API 100%. One false positive remaining of the original sixteen.

21,200 req/s
BLOCK PATH, P99 8.5 MS
Full pipeline: ML, ClickHouse logging and tenant tagging all active. Zero false shedding at sustained load.

7,950 req/s
CLEAN PASS-THROUGH, P99 15 MS
Measured with the ruleset as it actually loads (see CRS coverage in the matrix). Baseline direct-to-origin on the same hardware is 16,917 req/s — the origin round-trip dominates.

100%
REQUESTS SERVED THROUGH A MASTER REBOOT
Zero failed of 1,279 requests during a full VM reboot of the active node. Worst single request 1.055 s, still a complete 200.

3.5 s
VIP FAILOVER ON PROCESS KILL
98.81% success — 13 of 1,090 requests failed. Failback zero-loss, VIP restored in ~17 s.

888
AUTOMATED TESTS, ZERO FAILURES
691 Rust and 197 Go, measured 13 August 2026.

How the detection figure was reached — and why the path matters

The detection score was not achieved by tuning thresholds. It came from finding four places where a component was judging data it could not see. That history is worth a CTO's attention because it is the difference between a number that holds and one that collapses on a new corpus.

BUILD STEP	APP TP	BENIGN ALLOWED	COMPOSITE
Rule signatures only — the empirical ceiling of a regex-only approach	43.4%	92.9%	61.5%
+ coverage signatures (CRLF, SMTP/IMAP, LDAP, SSTI, NoSQL)	49.3%	91.5%	63.7%
+ embedded ML char-n-gram classifier	57.2%	88.7%	75.6%
+ FP-suppression model and base64 rule visibility	99.2%	88.7%	97.2%
+ score header/cookie values and parsed-multipart bodies	**99.09%**	**99.29%**	**99.60%**

Note the last row: **true positives rose while false positives fell.** Nothing was traded off. The recurring root cause each time was a component unable to see the data it was asked to judge — reachability, not model quality.

> **Two numbers to retire from internal material**
> Earlier roadmap documents quote **>500,000 req/s at p99 <1 ms**. Those are design targets and sit roughly 25× above what has been measured. Please treat the figures on this page as the only quotable performance numbers.

4 Honest scorecard

Where we genuinely lead

- **Onboarding speed** — API or YAML, live in seconds, zero restart. F5 needs policy plus virtual-server attach; HaltDOS is console-driven.
- **Truthful enforcement status** — the console reports which rules are actually running on each node. No competitor offers this.
- **Measured evasion resistance** — 99.09% app true-positive. Neither F5 nor HaltDOS publishes a comparable figure.
- **Modern API security in one policy** — GraphQL, JWKS and gRPC together.
- **Sandboxed WASM plugins** in any language, hot-swappable.
- **India PII in DLP** — PAN and Aadhaar built in.
- **Air-gapped single-tenant deployment** with data residency by construction.

Where we trail — do not claim parity

Every item below, plus the operational defects behind them, is tracked with evidence in `FIXES-TO-BE-MADE.md` at the repository root.

- **Partial CRS rule compatibility.** About half the shipped ruleset loads; ModSecurity-based products (BunkerWeb, and anything on libmodsecurity) run it whole. Our detection score is higher than theirs, but the coverage claim is not ours to make yet.
- **No positive-security / entity-learning model.** This is F5's core differentiator and our API discovery is a toggle only.
- **5 response actions vs HaltDOS's 13** — no tarpit, custom response or redirect.
- **Fewer authorable rule categories** than HaltDOS.
- **Rule authoring UI withheld** — the validator does not parse our real grammar yet.
- **No global scrubbing network** — and no roadmap to one.
- **No third-party audit, red team or compliance attestation.** A procurement blocker independent of engineering quality.
- **No vendor threat-research team.**
- **Real-traffic false-positive rate unmeasured.** See §6.

For reference, a coverage audit against the **eNlight Pratihar WAAP** reference specification assessed **35 covered, 36 partial, 43 gaps** across roughly 114 functionalities. The core engine scored strongly; API security was the weakest domain and has since been the focus of two build phases.

5 Roadmap — what closes, and what does not

Most gaps in §4 are scheduled. Two are not, and saying so is what makes the rest credible.

Phases that close identified gaps

RELEASE	THEME	CLOSES	GAP ADDRESSED
v1.0 GA Phase 7	Production hardening & assurance	Continuous fuzzing of rule, HTTP and WASM parsers · third-party security audit · external red team · performance certification · Helm chart and Kubernetes operator · Terraform modules · SOC 2 / PCI-DSS / ISO 27001 readiness pack · documentation site	Audit · red team · compliance
v1.1	API security depth	API auto-discovery generating an OpenAPI spec from observed traffic · OpenAPI schema enforcement · BOLA / IDOR detection · gRPC deep-protobuf introspection · verified good-bot allow-listing by reverse DNS	API discovery · schema · good bots
v1.1	Operator surface	Rule authoring UI backed by the real grammar validator · expanded response actions (tarpit, custom response, redirect) · additional authorable rule categories	Response actions · authoring

RELEASE	THEME	CLOSES	GAP ADDRESSED
Post v1.1	Learning & adaptive defence	Positive-security model with per-endpoint learning and drift detection · adaptive L7 DDoS with EWMA and storm detection · SAML SSO · enforced administrator MFA · LDAP / Active Directory	Positive security · L7 DDoS · SAML
Post v1.1	Cryptography & zero trust	Post-quantum TLS (hybrid X25519 + Kyber768) · zero-trust mTLS via SPIFFE/SPIRE · subresource integrity monitoring · HSM / Vault key custody	PQ-TLS
Post v1.1	Scale-out	Multi-cluster federation with cross-region threat-intelligence sharing · global active-active clustering · clientless WebVPN reverse proxy with SSO and WebAuthn	Multi-region

Two gaps the roadmap does not close — deliberately

GAP	WHY IT STAYS OPEN, AND WHY THAT IS THE RIGHT DECISION
Global anycast multi-Tbps DDoS scrubbing	This is a CDN business, not a WAF feature. Closing it means building and operating global points of presence — a capital programme measured in hundreds of crores, competing directly with Cloudflare and Akamai on their strongest ground. The correct architecture is to sit *behind* volumetric scrubbing, whether that is an upstream provider or ESDS network capacity, and to be the best inspection layer available on-premise. **Positioning ESDSWAF against Cloudflare on this row invites the one comparison we cannot win.**
Vendor threat-research team	A staffing and operating-model decision, not an engineering task. We consume upstream OWASP CRS and commercial threat-intelligence feeds. Matching Imperva or Akamai here means funding a standing research function — a business case worth making on its own merits, not something a release closes.

6 The gap that matters most — and it is not a feature

Every detection figure in §3 comes from a **synthetic corpus**. GoTestWAF measures whether we catch known attack classes and whether we pass its benign samples. It cannot tell us how often this WAF would wrongly block *a real customer's real users*.

That number has never been measured. No amount of detection accuracy substitutes for it, because the failure mode it predicts — legitimate users blocked during business hours — is the one that loses accounts.

The product is built around this honestly rather than around it:

- Every new site is onboarded in **learning mode**, which records what it would have blocked without blocking it.
- `fpr-report.sh` measures the rate over a chosen window, and the operator manual instructs reading the *denominator*, not just the percentage.
- A documented **four-point go-live gate** must pass before any site is switched to blocking: a full business cycle in learning mode, a measured rate under 1% on real traffic, every recurring detection classified, and application-owner sign-off.

> **Recommendation**
> The fastest way to close this gap is to put a real ESDS property behind the WAF in learning mode and let it accumulate genuine traffic. That produces the one number the product cannot currently quote — and it is worth more commercially than any feature that could be delivered in the same period.

Verification method. The SwarajKavach column was compiled by inspecting the source tree, test output and measured benchmark results — not from prior decks or roadmap documents, both of which were found to overstate several capabilities. Detection figures: GoTestWAF v0.5.8 against an all-methods origin. Performance: single node, full pipeline active. Failover: two independent probes at 0.3 s intervals, each response validated on status code and byte count. Test counts measured 13 August 2026.